Quick Policy: AI SQL Agent Usage

Applies to: Anyone deploying or using AI Text-to-SQL agents.

---

1. Read-Only Access

- **Agents must connect with SELECT-only permissions.**
- **No DROP, DELETE, UPDATE, INSERT, or ALTER permissions allowed.**

2. Guardrails & Limits

- **Row Limits: All queries must automatically append a result limit (e.g., LIMIT 100).**
- **Timeouts: Queries must terminate automatically if execution exceeds 15 seconds.**
- **Injection Defense: Validate inputs and parse SQL syntax before execution to block malicious code.**

3. Data Privacy

- **No PII: Mask or exclude sensitive user data (passwords, payment info, personal IDs) from prompt contexts and agent outputs.**
- **Schema Gating: Expose only authorized tables and columns to the model.**

4. Human Approval (For Writes)

- **If the agent is ever used for data modifications, an authorized human must explicitly review and approve the exact SQL query before execution.**

5. Logging

- **Every user prompt, generated query, execution time, and user ID must be logged for audit and security monitoring.**